

Managementul riscurilor – Clinica Medicală HealthPlus

Introducere

Această lucrare analizează riscurile cibernetice asociate activelor digitale ale clinicii medicale HealthPlus, o organizație care oferă servicii medicale complete și folosește sisteme informatice moderne pentru gestionarea datelor pacienților, a echipamentelor și a comunicării interne. Scopul acestei analize este de a identifica cele mai importante active, a evalua riscurile la care sunt expuse și a propune măsuri concrete pentru reducerea vulnerabilităților.

Pasul 1: Identificarea activelor

Am identificat următoarele active esențiale pentru funcționarea clinicii și le-am clasificat în funcție de importanța lor pentru continuitatea operațională.

	Activ	Clasificare	Descriere	Proprietar	Locație
1	Sistemul EHR	Critic	Stochează dosarele medicale ale pacienților	Departamentul Medical	Infrastructură cloud
2	Sistemul de informații de laborator	Critic	Gestionează analizele de laborator și rezultatele	Departamentul de laborator	Sala serverelor
3	Site-ul public	Necritic	Site informativ cu programări online	Departamentul de marketing	Furnizor de găzduire
4	Sistemul de e-mail	Important	Comunicare internă și externă	Departamentul IT	Infrastructură cloud
5	Echipamentele medicale	Critic	Echipamente conectate la rețea pentru diagnostic și tratament	Departamentul Medical	Cabinetele medicale

Pasul 2: Analiza amenințărilor și vulnerabilităților

Pentru fiecare activ, am identificat amenințările potențiale și vulnerabilitățile care pot fi exploatate. Această analiză a fost realizată pe baza experienței din industrie și a bunelor practici de securitate.

Activ	Amenințare	Vulnerabilitate	Descriere vulnerabilitate
Sistemul EHR	Acces neautorizat / atac cibernetic	Software neactualizat, autentificare slabă	Riscul de acces neautorizat la datele medicale ale pacienților
Sistemul de informații de laborator	Ștergere accidentală de date	Control slab al accesului	Personalul poate șterge date importante fără autorizare
Site-ul public	Atac DDoS	Lipsa protecției anti-DDoS	Site-ul poate deveni indisponibil în urma unui atac masiv
Sistemul de e-mail	Phishing / acces neautorizat	Lipsa autentificării MFA	Compromiterea conturilor prin e-mailuri frauduloase

Echipamente medicale	Malware / acces fizic neautorizat	Lipsă segmentare rețea, firmware învechit	Manipularea echipamentelor sau blocarea funcționării acestora
----------------------	-----------------------------------	---	---

Pasul 3: Evaluarea riscurilor

Pentru fiecare combinație de activ și amenințare, am estimat impactul potențial și probabilitatea apariției, determinând astfel nivelul de risc. Nivelul ridicat de risc necesită atenție prioritară și acțiuni rapide de atenuare

Activ	Amenințare	Impact	Probabilitate	Nivel de risc
Sistemul EHR	Acces neautorizat / atac cibernetic	Ridicat	Ridicată	Ridicat
Sistemul de informații de laborator	Ștergere accidentală de date	Mediu	Mediu	Mediu
Site-ul public	Atac DDoS	Scăzut	Ridicată	Mediu
Sistemul de e-mail	Phishing / acces neautorizat	Mediu	Ridicată	Ridicat
Echipamente medicale	Malware / acces fizic neautorizat	Ridicat	Mediu	Ridicat

Pasul 4: Strategia de mitigare

Am propus o serie de măsuri tehnice, administrative și fizice pentru reducerea fiecărui risc identificat. Acestea includ soluții de actualizare software, control al accesului, măsuri anti-DDoS, criptare, segmentare de rețea și altele.

Activ	Măsuri de atenuare
Sistemul EHR	Actualizare software, criptare, activare MFA
Sistemul de informații de laborator	Control acces pe roluri, audit de securitate
Site-ul public	Implementare protecție anti-DDoS, monitorizare permanentă
Sistemul de e-mail	Activare MFA, filtre anti-phishing, instruire utilizatori
Echipamente medicale	Segmentare rețea, restricționare acces fizic, actualizare firmware

Pasul 5: Implementare și monitorizare

Pentru fiecare măsură propusă, am definit etapele de implementare, responsabilul, termenele de execuție și comentarii specifice. Este esențial ca aceste măsuri să fie monitorizate constant și adaptate dacă apar noi riscuri sau vulnerabilități.

Etapa de implementare	Responsabil	Termen de finalizare	Comentarii
Actualizare software	Departamentul IT	1 lună	Patch management automat și periodic
Instalare sistem IPS	Departamentul IT	2 luni	Sistem de prevenire a intruziunilor în rețea
Dezvoltarea politicilor	Departamentul de securitate	1 lună	Politici de acces, control și reacție la incidente
Instruirea personalului	Departamentul HR	Trimestrial	Training-uri periodice, cursuri online și teste de verificare

Pasul 6: Instruirea personalului

Instruirea personalului este crucială pentru succesul oricărei strategii de securitate. Am inclus subiecte esențiale precum utilizarea sigură a parolelor, recunoașterea atacurilor de tip phishing și înțelegerea politicilor de securitate. Fiecare instruire are o formă adaptată, o frecvență clară și un responsabil desemnat.

Subiect de instruire	Formă de instruire	Frecvență	Responsabil
Utilizarea sigură a parolelor	Video + testare online	Trimestrial	Departamentul HR
Recunoașterea atacurilor phishing	Webinar + prezentare interactivă	Lunar	Departamentul de securitate
Politicile de securitate	Training fizic + materiale scrise	Semestrial	Departamentul de securitate

Concluzii

Prin această analiză am obținut o imagine clară asupra riscurilor care pot afecta activitatea clinicii HealthPlus. Implementarea măsurilor propuse, alături de instruirea periodică a personalului, poate reduce semnificativ probabilitatea și impactul incidentelor de securitate. Este esențial ca aceste acțiuni să fie revizuite și actualizate în mod regulat pentru a răspunde amenințărilor emergente din mediul digital.